

SIMATS ENGINEERING

ASSESSMENT TOOL 3: COMPARATIVE ANALYSIS

Course Code: CSA51 | Course Name: Cryptography and Network Security

Student Name: T.Lakshmi Prasad Naidu

Register Number: 192324187

Course Outcome: CO4 (BL3, BL6)

Assessment Weightage: 10% (Total Marks: 25)

Code of Conduct Declaration:

I, T.Lakshmi Prasad Naidu (Reg No: 192324187), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: T.Lakshmi Prasad Naidu

1. SSL/TLS vs. IPsec: Web-Based and Network-Layer Protection

Scenario Context

An enterprise hosts a cloud-based ERP application that remote employees access via web browsers, while distributed branch offices require seamless inter-site LAN connectivity across the public Internet.

Comparative Dimension	SSL / TLS (Transport Layer)	IPsec (Network Layer)
OSI Operating Layer	Layer 4/7 (Transport / Application Layer). Operates directly above TCP.	Layer 3 (Network Layer). Operates directly at the IP datagram layer.
Granularity & Scope	Application-specific (Per-session / Per-process). Protects specific ports/URLs (e.g., HTTPS, SMTPS).	Network-wide / Host-wide. Transparently protects all packets, subnets, and protocols (TCP, UDP, ICMP).
Client Setup & UX	Zero-footprint client. Natively supported across all modern web browsers without special drivers.	Requires dedicated VPN client software, virtual TAP adapters, or hardware gateway configuration.
Header Protection	Protects application data; IP and TCP transport headers remain unencrypted.	Tunnel Mode encapsulates and encrypts the entire original IP packet, concealing source/destination hosts.
Key Exchange Mechanism	TLS Handshake (RSA / ECDHE key exchange) with X.509 server PKI certificates.	Internet Key Exchange (IKEv1 / IKEv2) via Diffie-Hellman, Pre-Shared Keys, or Digital Certificates.
NAT & Firewall Traversal	Natively traverses NATs, proxies, and firewalls on standard port 443 without friction.	Requires NAT-Traversal (NAT-T via UDP port 4500) and specific firewall rule exceptions for IP Protocol 50 (ESP).

Analytical Evaluation & Architectural Determination

• **Web-Based Security Superiority (SSL/TLS):** For public web services, customer portals, and browser-driven SaaS, SSL/TLS is strictly superior. It eliminates endpoint management overhead,

integrates seamlessly with OAuth/SAML web identity flows, and enforces end-to-end encryption up to the application reverse proxy without exposing internal enterprise subnets.

• **Network-Layer Protection Superiority (IPsec):** For Site-to-Site branch interconnection, router-to-router tunneling, and legacy non-web protocols (SSH, SMB, RDP, VoIP), IPsec is unmatched. Operating at Layer 3 allows it to transparently secure all upper-layer traffic without modifying individual enterprise applications.

2. Secure Email System: End-to-End vs. Gateway-Based Encryption

Scenario Context

An enterprise organization with 15,000 corporate users requires confidential email communications while maintaining strict regulatory compliance (HIPAA/GDPR), automated Data Loss Prevention (DLP), and centralized malware scanning.

Architectural Parameter	End-to-End Encryption (PGP / S/MIME)	Gateway-Based Encryption (SEG / TLS / MTA-STS)
Encryption Endpoint	Sender's local client (Outlook, Thunderbird, Webmail) to Receiver's local client.	Sender Gateway (MTA / SEG) to Receiver Gateway (MTA / SEG) across the WAN.
Trust Model & Privacy	True Zero-Trust: Mail servers and network intermediaries cannot read email contents.	Hop-by-Hop Trust: Email exists in plaintext inside the corporate gateway boundary before forwarding.
DLP & Content Inspection	Incompatible: Encrypted payload blocks gateway DLP keyword filtering, antivirus, and spam analysis.	Fully Compatible: Central gateway inspects, sanitizes, logs, and applies policy-based encryption rules.
Key Management Overhead	High: Requires distributing, renewing, and revoking X.509 certs or PGP public keys for every user.	Low: Centralized certificate management on edge MTAs; completely transparent to end-users.
Mobile & UX Complexity	High friction: Users must manage private keys, passphrases, and certificates across mobile devices.	Zero friction: Users send normal emails; gateway automatically encrypts based on policy/metadata tags.
Legal Discovery & Archiving	Difficult: Decrypting historical archived mail requires enterprise-wide key escrow recovery.	Seamless: Messages are decrypted and indexed at the gateway prior to compliant immutable archiving.

Enterprise Architectural Recommendation & Justification

• **Recommended Approach: Policy-Driven Hybrid Architecture.**

1. Primary Enterprise Baseline (Gateway-Based Encryption): The organization should deploy Secure Email Gateways (SEGs) enforcing enforced DANE/MTA-STS and TLS 1.3 for 95% of standard employee communication. This enables automated DLP enforcement, zero user training, centralized anti-malware scrubbing, and unhindered compliance archiving.
2. Targeted High-Security Tier (Client-Side S/MIME / PGP): For executive boards, legal departments, and R&D intellectual property teams, client-side S/MIME with centralized key escrow is enforced to guarantee true end-to-end confidentiality against internal insider threats and compromised infrastructure.

3. HMAC vs. Digital Signatures: Authentication and Integrity Analysis

Scenario Context

Evaluating cryptographic controls for high-volume REST API financial transaction microservices (requiring sub-millisecond execution) versus legally binding contract signing and software binary distribution.

Cryptographic Feature	HMAC (Hash-based Message Auth Code)	Digital Signatures (RSA-PSS / ECDSA)
Underlying Primitive	Symmetric Shared Secret Key + Cryptographic Hash (SHA-256 / SHA-3).	Asymmetric Keypair (Private Signing Key + Public Verification Key).
Computational Speed	Extremely Fast ($O(1)$ stream hashing). Ideal for microsecond API latencies.	Computationally Intensive (Requires asymmetric modular exponentiation / scalar EC math).
Authentication Scope	Shared Identity: Proves that an entity possessing the shared secret generated the tag.	Individual Identity: Mathematically proves the exact unique identity of the private key holder.
Non-Repudiation	No Non-Repudiation: Both sender and receiver share the same key; sender can deny transmission.	Absolute Non-Repudiation: Private key is unique to signer; provable in a court of law.
Bandwidth Overhead	Minimal: Fixed 32-Byte (256-bit) digest appended to message payload.	Moderate to High: 256–512 Bytes (RSA-2048/4096) or 64 Bytes (ECDSA P-256) plus X.509 cert chains.
Key Distribution	Requires secure out-of-band shared secret distribution (e.g., Vault, KMS).	Public keys are distributed freely via Public Key Infrastructure (PKI) / X.509 certs.

Authentication and Integrity Comparative Analysis

- **Integrity Guarantee:** Both HMAC and Digital Signatures provide cryptographic integrity. Any single-bit tampering of the plaintext during transit results in complete verification failure.
- **Authentication & Non-Repudiation Winner:** Digital Signatures provide superior unilateral authentication and non-repudiation because the signer cannot claim the receiver forged the signature. HMAC is optimal for high-throughput distributed architectures (e.g., AWS Signature v4, API Gateway tokens), while Digital Signatures are indispensable for legal non-repudiation, code signing, and identity federation.

4. Spam Detection: Supervised vs. Unsupervised Machine Learning

Scenario Context

Designing an enterprise email security filtering engine to classify incoming mail streams into Legitimate (Ham), Spam, Phishing, and Zero-Day Business Email Compromise (BEC) attacks.

Evaluation Aspect	Supervised Learning (e.g., Naive Bayes, SVM, XGBoost)	Unsupervised Learning (e.g., Isolation Forest, Autoencoders, K-Means)
Training Data	Requires large historical corpora of	Operates directly on raw, unlabeled email

Requirement	accurately labeled emails (Spam vs. Ham).	telemetry and behavioral metadata.
Zero-Day & Concept Drift	Vulnerable to novel adversarial attacks until newly labeled training samples are ingested.	Highly effective at catching zero-day anomalies, abnormal sender deviations, and novel BEC attacks.
False Positive Handling	Low False Positive Rate: Explicit boundary thresholds tuned precisely to minimize blocking valid mail.	Higher False Positive Rate: Legitimate unconventional emails may be flagged as behavioral anomalies.
Feature Representation	Lexical NLP tokens, TF-IDF n-grams, known spam keywords, and static heuristics.	Sender baseline behavioral profiles, graph communication clusters, and embedding latent spaces.
Operational Retraining	Requires continuous batch labeling, offline retraining pipelines, and verification.	Dynamically updates baseline clustering models online with incoming telemetry streams.

Real-World Effectiveness Evaluation & Optimal Architecture

- **Effectiveness Analysis:** Supervised models deliver high precision on known spam campaigns (99.2%+ accuracy), but fail against sophisticated zero-day targeted phishing. Unsupervised models excel at spotting behavioral outliers (e.g., an executive suddenly emailing from a new IP requesting wire transfers), but risk business disruption if uncalibrated.
- **Recommended Multi-Tiered Defense Architecture:**
 - Tier 1 (Pre-Filter Heuristics): SPF/DKIM/DMARC verification + DNSBL IP blacklists.
 - Tier 2 (Supervised Classifier): Multi-class Naive Bayes / LightGBM pipeline on TF-IDF token vectors to catch 98% of bulk commodity spam.
 - Tier 3 (Unsupervised Anomaly Engine): Isolation Forest / Autoencoder scoring communication graphs to flag zero-day Business Email Compromise (BEC).

5. Secure Communication Framework: AES vs. RSA Encryption

Scenario Context

Architecting a cryptographic communication pipeline to protect multi-gigabyte data storage and real-time network transmissions while maintaining strict mathematical confidentiality and microsecond responsiveness.

Cryptographic Metric	AES (Advanced Encryption Standard)	RSA (Rivest-Shamir-Adleman)
Cryptographic Category	Symmetric Block Cipher (SPN - Substitution Permutation Network).	Asymmetric Public-Key Cryptosystem (Integer Factorization Trapdoor).
Key Size & Strength	128, 192, 256 bits (AES-256 provides quantum-resistant 128-bit post-quantum security).	2048, 3072, 4096 bits (RSA-2048 provides classical 112-bit security; vulnerable to Shor's algorithm).
Execution Speed / Throughput	Gigabytes per second (Hardware accelerated via Intel AES-NI / ARM Crypto).	Kilobytes per second (Slow modular exponentiation: $C = M^e \bmod n$).
Data Processing Capacity	Arbitrary bulk data streams (Multi-GB files, video streams, database disk blocks).	Strictly limited to payload sizes smaller than key modulus (e.g., max 190 Bytes for RSA-2048 OAEP).

Primary Cryptographic Role	Bulk Data Confidentiality and at-rest / in-transit payload encryption.	Key Encapsulation Mechanism (KEM), Digital Signatures, and Initial Identity Authentication.
-----------------------------------	--	---

Framework Design: Achieving Confidentiality and Efficiency

• Fundamental Architectural Division:

Neither cipher is sufficient in isolation: RSA is too computationally slow for bulk data ($1000\times$ slower than AES), while AES suffers from the $O(n^2)$ shared secret distribution problem across distributed networks.

• The Hybrid Cryptosystem Blueprint:

1. Asymmetric Phase (RSA-OAEP / ECDH): The client and server use RSA public keys (or ECDH ephemeral exchanges) to authenticate identity and securely exchange a randomly generated 256-bit AES session key.
2. Symmetric Phase (AES-256-GCM): Once the session key is established, all high-volume application payload data is encrypted using AES-GCM, delivering authenticated encryption with associated data (AEAD) at wire speed with zero CPU bottleneck.